

Informe Final de Pentesting

Propuesta de Mitigación y Prevención de Vulnerabilidades

Laboratorio: The Lovers

Alumno: Álvaro Chagas

Proyecto: Pentesting Report Prevention Proposal

Fecha: Agosto 2026

Índice

1. Introducción
2. Objetivos
3. Metodología
4. Fase de reconocimiento
5. Vulnerabilidades identificadas
6. Técnicas de explotación utilizadas
7. Propuesta de mitigación
8. Buenas prácticas de seguridad
9. Conclusiones
10. Bibliografía

1. Introducción

El presente informe tiene como finalidad consolidar los conocimientos adquiridos durante las prácticas de pentesting realizadas sobre la máquina vulnerable **The Lovers**, analizando las vulnerabilidades identificadas, las técnicas empleadas para su explotación y proponiendo medidas de mitigación que permitan reducir la superficie de ataque y fortalecer la seguridad del sistema.

Durante el desarrollo del laboratorio se llevaron a cabo tareas de reconocimiento, enumeración y análisis del servicio web expuesto por la máquina objetivo. Posteriormente, se verificó la existencia de una vulnerabilidad en el mecanismo de autenticación que permitió obtener acceso no autorizado a la aplicación, demostrando el impacto que puede tener una configuración insegura de un sistema web.

El objetivo principal de este informe es presentar recomendaciones orientadas a prevenir este tipo de ataques y promover la implementación de buenas prácticas de seguridad.

2. Objetivos

Objetivo General

Analizar las vulnerabilidades detectadas durante el proceso de pentesting de la máquina **The Lovers**, evaluando su impacto y proponiendo medidas de mitigación para prevenir futuros ataques.

Objetivos específicos

- Analizar la superficie de ataque del servidor.
- Identificar los servicios expuestos.
- Evaluar la seguridad del formulario de autenticación.
- Documentar la vulnerabilidad explotada.
- Proponer medidas de prevención y endurecimiento del sistema.
- Promover buenas prácticas de seguridad ofensiva y defensiva.

3. Metodología

Para el desarrollo del laboratorio se siguió una metodología basada en las etapas clásicas de un proceso de pentesting:

- Reconocimiento.
- Descubrimiento de hosts.
- Enumeración de servicios.
- Identificación de tecnologías.
- Enumeración de recursos web.
- Análisis del formulario de autenticación.
- Explotación de la vulnerabilidad identificada.
- Obtención de evidencias.
- Elaboración de propuestas de mitigación.

Las herramientas utilizadas fueron:

- arp-scan
- Nmap
- WhatWeb
- Gobuster
- Curl

4. Fase de reconocimiento

La primera etapa consistió en identificar la máquina objetivo dentro de la red local mediante técnicas de descubrimiento de hosts activos.

Posteriormente se realizó un escaneo de puertos con Nmap, identificando únicamente dos servicios expuestos:

- Puerto 22/TCP (SSH)
- Puerto 80/TCP (HTTP)

El análisis permitió determinar que el servidor ejecutaba Ubuntu Linux con Apache HTTP Server como servidor web.

Posteriormente se inspeccionó la aplicación alojada en el puerto 80, observándose un formulario de autenticación compuesto por un campo de usuario y un campo de contraseña enviados mediante el método POST.

Finalmente, mediante herramientas de enumeración se identificaron distintos recursos internos del servidor, incluyendo archivos protegidos por Apache y el módulo **server-status**, el cual se encontraba restringido mediante controles de acceso.

5. Vulnerabilidades identificadas

5.1 Servicio HTTP expuesto

Descripción

El servidor expone públicamente una aplicación web accesible mediante HTTP.

Aunque esto es completamente normal para un servicio web, representa el principal punto de entrada para un posible atacante.

Riesgo

Medio

Impacto

- Acceso a la aplicación por cualquier usuario.
- Posibilidad de realizar ataques automatizados.
- Enumeración de recursos.
- Ataques de fuerza bruta.

Medidas de mitigación

- Implementar HTTPS.
- Configurar certificados TLS válidos.
- Habilitar HSTS.
- Utilizar un Web Application Firewall (WAF).

- Limitar el acceso cuando sea posible.

5.2 Exposición del servicio SSH

Descripción

El servidor mantiene habilitado el servicio SSH para administración remota.

Aunque SSH es un protocolo seguro, su exposición aumenta la superficie de ataque.

Riesgo

Medio

Impacto

- Ataques de fuerza bruta.
- Intentos de acceso remoto.
- Enumeración de usuarios.

Medidas de mitigación

- Deshabilitar el acceso del usuario root.
- Utilizar autenticación mediante claves públicas.
- Cambiar el puerto por defecto (cuando sea apropiado).
- Implementar Fail2Ban.
- Restringir el acceso por direcciones IP autorizadas.

5.3 Formulario de autenticación vulnerable

Descripción

Durante el análisis del formulario de autenticación se identificó una vulnerabilidad de **inyección SQL (SQL Injection)**.

La explotación de esta vulnerabilidad permitió eludir el mecanismo de autenticación de la aplicación y acceder sin disponer de credenciales válidas, obteniendo acceso no autorizado y completando exitosamente el laboratorio mediante la recuperación de las evidencias (flags) requeridas.

Riesgo

Crítico

Impacto

- Bypass de autenticación.
- Acceso no autorizado.

- Exposición de información sensible.
- Compromiso potencial de la base de datos.
- Escalada de privilegios dependiendo de los permisos de la aplicación.

Medidas de mitigación

- Utilizar consultas preparadas (Prepared Statements).
- Implementar sentencias parametrizadas.
- Emplear ORM cuando sea posible.
- Validar todas las entradas del usuario.
- Escapar caracteres especiales.
- Aplicar el principio del menor privilegio en la base de datos.
- Implementar un Web Application Firewall.
- Registrar y monitorear los intentos de autenticación.

5.4 Enumeración de directorios

Descripción

La utilización de Gobuster permitió identificar distintos recursos existentes dentro del servidor web.

Aunque varios de ellos estaban protegidos mediante respuestas **403 Forbidden**, su existencia proporciona información útil para un atacante.

Riesgo

Bajo

Impacto

- Enumeración de recursos internos.
- Obtención de información sobre la configuración del servidor.

Medidas de mitigación

- Eliminar archivos innecesarios.
- Deshabilitar listados de directorios.
- Restringir completamente el acceso a recursos administrativos.
- Revisar periódicamente la configuración de Apache.

5.5 Divulgación de información tecnológica

Descripción

Las herramientas de reconocimiento permitieron identificar el sistema operativo, la versión de Apache y las tecnologías utilizadas por la aplicación.

Esta información facilita la búsqueda de vulnerabilidades específicas.

Riesgo

Bajo

Medidas de mitigación

- Ocultar banners del servidor.
- Minimizar la información devuelta en las respuestas HTTP.
- Mantener actualizado el software.

6. Técnicas de explotación utilizadas

Durante el laboratorio se aplicaron diferentes técnicas propias de un proceso de pentesting:

- Descubrimiento de hosts mediante arp-scan.
- Escaneo de puertos con Nmap.
- Fingerprinting de tecnologías con WhatWeb.
- Enumeración de directorios utilizando Gobuster.
- Inspección del código fuente HTML.
- Análisis del formulario de autenticación.
- Explotación de una vulnerabilidad de SQL Injection presente en el proceso de autenticación.
- Verificación del acceso obtenido mediante la recuperación de las evidencias (flags) del laboratorio.

7. Propuesta de mitigación

Con el objetivo de reducir la superficie de ataque y evitar vulnerabilidades similares se recomienda:

Seguridad de la aplicación

- Utilizar consultas parametrizadas.
- Validar toda entrada del usuario.
- Implementar controles contra SQL Injection.
- Incorporar autenticación multifactor cuando sea posible.
- Establecer políticas de contraseñas robustas.

- Limitar los intentos de autenticación.
- Implementar bloqueo temporal ante múltiples intentos fallidos.

Seguridad del servidor

- Mantener Ubuntu actualizado.
- Actualizar Apache periódicamente.
- Deshabilitar módulos innecesarios.
- Restringir el acceso a server-status.
- Revisar permisos de archivos sensibles.
- Deshabilitar servicios que no sean necesarios.

Seguridad de red

- Configurar firewall.
- Limitar accesos mediante listas de control (ACL).
- Restringir SSH únicamente a redes administrativas.
- Registrar todos los accesos remotos.

Monitoreo

- Centralizar los registros del sistema.
- Implementar un SIEM.
- Configurar alertas de intentos de acceso sospechosos.
- Realizar auditorías periódicas.
- Ejecutar pruebas de pentesting de manera recurrente.

8. Buenas prácticas de seguridad

Como resultado del análisis realizado, se recomienda adoptar las siguientes buenas prácticas:

- Aplicar el principio del menor privilegio.
- Mantener actualizado todo el software instalado.
- Realizar copias de seguridad periódicas.
- Implementar autenticación multifactor.
- Capacitar al personal sobre buenas prácticas de seguridad.
- Ejecutar análisis automáticos de vulnerabilidades.
- Realizar pruebas de penetración de forma periódica.

- Revisar continuamente la configuración del servidor web.

9. Conclusiones

El proceso de pentesting permitió identificar la superficie de ataque de la máquina **The Lovers**, compuesta principalmente por los servicios SSH y HTTP. El reconocimiento y la enumeración facilitaron la identificación de las tecnologías utilizadas y del formulario de autenticación como principal punto de entrada de la aplicación.

La explotación del mecanismo de autenticación demostró la existencia de una vulnerabilidad crítica de **SQL Injection**, permitiendo el acceso no autorizado al sistema y la recuperación satisfactoria de las evidencias requeridas por el laboratorio. Este resultado pone de manifiesto la importancia de implementar mecanismos adecuados de validación de entradas, consultas parametrizadas y controles de seguridad adicionales para proteger las aplicaciones web frente a este tipo de ataques.

Las medidas de mitigación propuestas buscan reducir significativamente la probabilidad de explotación de vulnerabilidades similares, fortaleciendo tanto la seguridad del servidor como la de la aplicación web. Asimismo, se destaca la importancia de complementar estas acciones con un monitoreo continuo, auditorías periódicas y pruebas de penetración recurrentes, promoviendo un enfoque de mejora continua en materia de ciberseguridad.

10. Bibliografía

- OWASP Foundation. *OWASP Top 10 – Web Application Security Risks*.
- OWASP SQL Injection Prevention Cheat Sheet.
- NIST SP 800-115 – Technical Guide to Information Security Testing and Assessment.
- Apache HTTP Server Documentation.
- Ubuntu Server Documentation.
- Nmap Reference Guide.
- Gobuster Documentation.
- WhatWeb Documentation.